Phase 1:

PHẦN 1: TỔNG KẾT TỔNG QUAN PHASE 1 (EXECUTIVE SUMMARY)

Chuyển hóa thành công một bản thiết kế lý thuyết kiến trúc doanh nghiệp thành một hệ thống thực thi 100% bằng Terraform (Infrastructure as Code) trên AWS Region Singapore (ap-southeast-1).

Kết quả:

1. Kiến trúc mạng phân tầng chuẩn Enterprise (3-Tier Multi-AZ VPC): Tách bạch hoàn toàn giữa 3 lớp: *Public (ALB/NAT)*, *Private App (EC2)* và *Isolated Database (RDS)* qua 2 Availability Zones (ap-southeast-1a và ap-southeast-1b).
2. Triệt tiêu lỗ hổng theo nguyên tắc Zero-Trust: Cổng 22 (SSH) bị đóng hoàn toàn trên toàn bộ hệ thống; quản trị viên truy cập terminal qua AWS Systems Manager (SSM) Session Manager; bắt buộc sử dụng IMDSv2 chống tấn công SSRF.
3. Cơ chế chịu lỗi và tự phục hồi (Self-Healing & High Availability):
    - Tầng Compute: Auto Scaling Group kết hợp Application Load Balancer tự động loại bỏ máy ảo lỗi và bật máy mới thay thế mà người dùng không gặp bất kỳ mã lỗi 5xx nào.
    - Tầng Data: Amazon RDS Multi-AZ đồng bộ dữ liệu vật lý theo thời gian thực (Synchronous Physical Replication), tự động failover chỉ trong ~60 giây khi có sự cố.
4. Bảo mật danh tính & Quản trị dữ liệu bí mật: DB credentials được sinh ngẫu nhiên, mã hóa và lưu trữ tập trung tại AWS Secrets Manager, máy ảo EC2 dùng IAM Instance Profile theo nguyên tắc quyền tối thiểu (Least Privilege).

5. Tối ưu chi phí thực nghiệm (FinOps): Tiết kiệm chi phí nhờ sử dụng chip AWS Graviton (t4g.micro) và tùy chọn 1 NAT Gateway trong môi trường lab.

PHẦN 2: GIẢI THÍCH FULL TỪNG BƯỚC ĐÃ THỰC HIỆN

Quy trình triển khai Phase 1 đã tuân thủ nghiêm ngặt 5 giai đoạn kỹ thuật:

[BƯỚC 0: FINOPS & STATE] —> [BƯỚC 1: APP & BOOTSTRAP] —> [BƯỚC 2: TERRAFORM MODULES] —> [BƯỚC 3: DEPLOYMENT] —> [BƯỚC 4: FAULT INJECTION & DRILL]

Bước 0: Thiết lập rào chắn chi phí & Quản lý Remote State

- Mục đích: Đảm bảo an toàn tài chính và chống xung đột file trạng thái khi chạy lệnh Terraform.
- Thực thi: Tạo AWS Budget $15 USD (báo động khi chạm 80%), tạo S3 Bucket (bật Versioning + SSE Encryption) và DynamoDB Lock Table (hoặc use_lockfile) để lưu trữ tập trung file terraform.tfstate.

Bước 1: Xây dựng Diagnostic Web App & Kịch bản Bootstrapping

- Mục đích: Cung cấp ứng dụng để Load Balancer kiểm tra sức khỏe (/healthz) và hiển thị trực quan thông số máy chủ.
- Thực thi: Viết ứng dụng Node.js (Express) tích hợp chuẩn IMDSv2 Token, kết nối PostgreSQL qua SSL (rejectUnauthorized: false), có sẵn nút test /api/stress-cpu và /api/simulate-500. Đóng gói quá trình cài đặt vào file user_data.sh chạy dưới dạng service systemd.

Bước 2: Thiết kế và module hóa mã nguồn Terraform

- Mục đích: Tách biệt các khối tài nguyên để dễ bảo trì, tái sử dụng và mở rộng cho các phase sau.

- Thực thi: Tạo 6 module độc lập: vpc, security_groups, security (IAM + Secrets), rds, alb, asg. Mở sẵn các "chân cắm" (ports/variables) để chuẩn bị cho Phase 2 (CI/CD), Phase 3 (Monitoring), Phase 4 (WAF) và Phase 5 (Disaster Recovery)

Bước 3: Điều phối và Triển khai môi trường (Primary Singapore)

- Mục đích: Kết nối các module và tạo tài nguyên thực tế trên AWS.
- Thực thi: Viết file main.tf trong environments/primary-singapore, truyền output của module này làm input của module khác, chạy terraform apply -auto-approve.

Bước 4: Kiểm thử sự cố thực tế & Thu thập minh chứng (Verification Drill)

- Mục đích: Kiểm chứng tính bền vững của hệ thống qua 4 kịch bản thực nghiệm:
    1. Kiểm tra truy cập Zero-Trust qua AWS SSM.
    2. Kiểm tra cân bằng tải Multi-AZ và giao diện Diagnostic Hub.
    3. Giả lập sập máy ảo EC2 để kiểm tra Auto-Healing và Zero-Downtime.
    4. Cưỡng chế Failover cơ sở dữ liệu RDS Multi-AZ.
    5. Kiểm toán cách ly mạng của Isolated DB Subnet.

PHẦN 3: CẤU TRÚC CHI TIẾT TỪNG FILE MÃ NGUỒN VÀ Ý NGHĨA KỸ THUẬT

1. Tầng Ứng dụng & Bootstrapping (app/)

- app/src/server.js:
    - *Ý nghĩa:* Trái tim của ứng dụng chẩn đoán.
    - *Chi tiết kỹ thuật:*

        - Hàm getIMDSv2Metadata() gửi request PUT lấy token phiên ngắn hạn từ 169.254.169.254/latest/api/token, sau đó gửi request GET kèm token để đọc instance-id, availability-zone, và local-ipv4. Điều này ngăn chặn hoàn toàn nguy cơ kẻ tấn công khai thác lỗ hổng SSRF để đánh cắp metadata.
        - Cấu hình Pool kết nối PostgreSQL với cờ ssl: { rejectUnauthorized: false }, đáp ứng chính sách mã hóa bắt buộc của AWS RDS.
        - Endpoint /healthz trả về HTTP 200 giúp ALB nhận diện instance khỏe mạnh.
- app/scripts/user_data.sh:
    - *Ý nghĩa:* Script tự động chạy khi máy ảo EC2 khởi động lần đầu (Cloud-init).
    - *Chi tiết kỹ thuật:* Tự động cập nhật gói hệ thống, cài đặt Node.js/NPM, nạp biến môi trường kết nối database (DB_HOST, DB_USER, DB_PASSWORD, DB_NAME), và tạo file dịch vụ /etc/systemd/system/cloud-app.service chạy ngầm. Giúp ứng dụng tự khởi động lại nếu bị crash (Restart=always).

2. Tầng Mạng (terraform/modules/vpc/)

- modules/vpc/main.tf:
    - *Ý nghĩa:* Khởi tạo toàn bộ xương sống mạng của hệ thống.
    - *Chi tiết kỹ thuật:*
        - Tạo VPC dải mạng 10.0.0.0/16.
        - Tạo 6 subnets: 2 Public (10.0.1.0/24, 10.0.2.0/24), 2 Private App (10.0.10.0/24, 10.0.20.0/24), 2 Isolated DB (10.0.100.0/24, 10.0.200.0/24) chia đều trên 2 AZs.
        - Tạo Internet Gateway cho Public Subnet.
        - Tạo NAT Gateway (kèm Elastic IP) gắn vào Public Subnet, cho phép các máy EC2 trong Private Subnet tải gói cập nhật từ Internet ra ngoài nhưng chặn hoàn toàn chiều ngược lại từ Internet đi vào.

        - Tạo 3 Route Tables riêng biệt:
            - public-rt: Route 0.0.0.0/0 trỏ ra Internet Gateway.
            - private-app-rt: Route 0.0.0.0/0 trỏ ra NAT Gateway.
            - isolated-db-rt: Chỉ có duy nhất route 10.0.0.0/16 -> local. Hoàn toàn không có đường ra IGW hay NAT GW.

3. Tầng Tường lửa Mạng (terraform/modules/security_groups/)

- modules/security_groups/main.tf:
    - *Ý nghĩa:* Áp dụng nguyên tắc phòng thủ chiều sâu (Defense-in-Depth) bằng kỹ thuật móc xích Security Group (Chaining SGs).
    - *Chi tiết kỹ thuật:*
        - alb-sg: Chỉ mở inbound cổng 80 (HTTP) từ toàn cầu (0.0.0.0/0).
        - app-ec2-sg: Đóng hoàn toàn cổng 22 (SSH). Chỉ cho phép inbound cổng 8080 nếu nguồn gửi đến xuất phát từ chính alb-sg (security_groups = [aws_security_group.alb.id]).
        - rds-sg: Chỉ cho phép inbound cổng 5432 (PostgreSQL) nếu nguồn gửi đến xuất phát từ app-ec2-sg. Bất kỳ ai, kể cả từ public internet hay từ chính ALB, đều không thể gõ cửa database.

4. Tầng Bảo mật & Định danh (terraform/modules/security/)

- modules/security/main.tf:
    - *Ý nghĩa:* Quản trị danh tính và thông tin xác thực an toàn.
    - *Chi tiết kỹ thuật:*
        - Tạo random_password dài 20 ký tự phức tạp và đẩy vào AWS Secrets Manager (aws_secretsmanager_secret).
        - Tạo IAM Role app-ec2-role và gắn policy AmazonSSMManagedInstanceCore để thay thế hoàn toàn SSH key, biến EC2 thành nút mạng Zero-Trust.

        - Cắm sẵn policy AmazonEC2RoleforAWSCodeDeploy (cho Phase 2 CI/CD) và CloudWatchAgentServerPolicy (cho Phase 3 Monitoring).
        - Tạo Inline Policy cấp quyền cho EC2 chỉ được đọc đúng Secret của database (secretsmanager:GetSecretValue).

5. Tầng Cơ sở dữ liệu (terraform/modules/rds/)

- modules/rds/main.tf:
    - *Ý nghĩa:* Cung cấp cơ sở dữ liệu quan hệ có độ tin cậy và sẵn sàng cao.
    - *Chi tiết kỹ thuật:*
        - aws_db_subnet_group: Buộc RDS phải nằm trên các Isolated Subnets của cả 2 AZ.
        - aws_db_instance: Chạy engine PostgreSQL phiên bản 16.2 với instance class db.t4g.micro (Graviton).
        - Bật cờ multi_az = true: Kích hoạt cơ chế 1 node Primary (Active) tại AZ-A và 1 node Standby tại AZ-B với cơ chế đồng bộ cấp block (Block-level Synchronous Replication).
        - Bật storage_encrypted = true (mã hóa dữ liệu tại chỗ) và publicly_accessible = false (không cấp public IP).
        - aws_secretsmanager_secret_version: Tự động nạp endpoint, cổng, username, password vào Secrets Manager sau khi RDS khởi tạo xong.

6. Tầng Cân bằng tải (terraform/modules/alb/)

- modules/alb/main.tf:
    - *Ý nghĩa:* Điểm tiếp nhận lưu lượng duy nhất từ Internet và phân phối tải thông minh.
    - *Chi tiết kỹ thuật:*

        - Tạo Application Load Balancer Internet-facing đặt trên 2 Public Subnet.
        - Tạo Target Group lắng nghe ở cổng 8080 với cấu hình Health Check thông minh: Kiểm tra đường dẫn /healthz, chu kỳ 15 giây, timeout 5 giây, chỉ cần 2 lần trả về HTTP 200 liên tiếp là đánh dấu Healthy, 3 lần lỗi là Unhealthy.
        - Mở sẵn biến waf_acl_arn để sang Phase 4 chỉ cần truyền ARN của WAF v2 vào là tự động kích hoạt bảo vệ tầng 7.

7. Tầng Tính toán co giãn (terraform/modules/asg/)

- modules/asg/main.tf:
    - *Ý nghĩa:* Tự động co giãn và đảm bảo số lượng máy ảo phục vụ người dùng.
    - *Chi tiết kỹ thuật:*
        - aws_launch_template: Dùng AMI Amazon Linux 2023 kiến trúc ARM64 chạy trên chip Graviton (t4g.micro). Bắt buộc bật http_tokens = "required" (IMDSv2). Nhúng mã script user_data.sh qua hàm templatefile để truyền động các thông số database.
        - aws_autoscaling_group: Phân bố máy ảo trải đều qua các Private App Subnet. Cấu hình min_size = 2, desired_capacity = 2, max_size = 4.
        - Cấu hình health_check_type = "ELB": ASG không chỉ nhìn vào phần cứng EC2 mà còn nhìn vào kết quả kiểm tra sức khỏe của ALB. Nếu ứng dụng web bị đơ, ASG sẽ lập tức xem máy đó là lỗi và thay thế máy mới.

8. Tầng Điều phối môi trường (terraform/environments/primary-singapore/)

- backend.tf: Trỏ lưu file trạng thái hạ tầng về S3 Bucket và dùng DynamoDB khóa trạng thái, đảm bảo không bao giờ bị mất hoặc đè state.

- main.tf: Nhập toàn bộ 6 module trên lại thành một hệ thống thống nhất, đóng vai trò là "nhạc trưởng" kết nối các output thành input.
- outputs.tf: Xuất ra các thông số quan trọng (alb_dns_name, rds_endpoint, asg_name, db_instance_id) phục vụ kiểm thử và kết nối với Region DR ở Phase 5.

PHẦN 4: ĐÁNH GIÁ CHI TIẾT CÁC BẰNG CHỨNG THỰC NGHIỆM (PROOF OF WORK)

Bằng chứng 1: Truy cập quản trị Zero-Trust qua AWS SSM (Scenario 1)

  - Lệnh thực thi: aws ssm start-session --target i-070cc2310daaf4374 --region ap-southeast-1.
  - Kết quả terminal: Phiên shell được mở thành công (Starting session with SessionId: terraform-user-...).
  - Lệnh whoami trả về: ssm-user.
  - Lệnh hostname trả về: ip-10-0-10-110.ap-southeast-1.compute.internal (đây chính xác là địa chỉ IP nội bộ nằm trong Private App Subnet).
- Đánh giá: Đã chứng minh hệ thống không hề mở cổng 22, không cần file PEM, nhưng kỹ sư vẫn có thể SSH-less vào debug máy chủ an toàn với đầy đủ log kiểm toán của AWS.

Bằng chứng 2: Cân bằng tải Multi-AZ & Trạng thái Ứng dụng (Scenario 2)

  - Target Groups trên Console: Hiển thị rõ 2 Total targets, cả 2 đều đạt trạng thái Healthy (2/2), được chia đều 1 node ở ap-southeast-1a (apse1-az2) và 1 node ở ap-southeast-1b (apse1-az1).
  - Trình duyệt Web 1: Truy cập qua ALB DNS, in ra máy i-070cc2310daaf4374 tại ap-southeast-1a (IP 10.0.10.110). Dòng

Database Status báo: Connected to [enterprisedb] at Thu Oct 08 2026 08:36:13 GMT+0000.

- Trình duyệt Web 2 (F5): ALB tự động điều hướng sang máy thứ hai i-0251367715a01d3e6 tại ap-southeast-1b (IP 10.0.20.200). Dòng Database Status báo: Connected to [enterprisedb] at Thu Oct 08 2026 08:57:46 GMT+0000.

- Đánh giá: Đã chứng minh ALB cân bằng tải đa vùng hoàn hảo, ứng dụng đọc đúng IMDSv2 và đã giải quyết triệt để lỗi SSL Postgres để kết nối thành công tới RDS Multi-AZ.

Bằng chứng 3: Tự phục hồi EC2 (Auto-Healing) & Zero-Downtime

- Terminal chạy vòng lặp curl: Các request gửi liên tục vào endpoint /healthz đều trả về mã 200 với độ trễ phản hồi cực thấp: 0.099s, 0.102s, 0.133s, 0.082s (chỉ có duy nhất 1 nhịp 0.616s khi ALB thực hiện ngắt kết nối an toàn). Tỷ lệ lỗi 5xx là 0%!
- Activity History trên ASG Console:
  - Sự kiện 1: Terminating EC2 instance: i-070cc... - Waiting for ELB Connection Draining (phát hiện máy bị dừng).
  - Sự kiện 2: Launching a new EC2 instance: i-0a79... in response to an unhealthy instance needing to be replaced.

- Đánh giá: Minh chứng rõ ràng tính năng tự phục hồi (Self-Healing) của tầng Compute. Khi có sự cố phần cứng, người dùng không hề bị gián đoạn dịch vụ nhờ cơ chế Connection Draining của ALB.

Bằng chứng 4: Cơ chế Failover tự động của RDS Multi-AZ (Scenario 3)

- Bảng Recent Events của RDS prod-primary-db ghi nhận chuỗi sự kiện theo đúng dòng thời gian:
  - 16:14: *Multi-AZ instance failover started.*
  - 16:15: *DB instance restarted.*
  - 16:15: *Multi-AZ instance failover completed.*

- Đánh giá: Tổng thời gian chuyển giao quyền Primary sang Standby và phục hồi hoàn toàn chỉ mất dưới 60 giây, hoàn toàn đáp ứng tiêu chuẩn Enterprise High Availability cho tầng dữ liệu.

Bằng chứng 5: Cô lập tuyệt đối tầng Dữ liệu (Scenario 4)

  - CLI: Lệnh aws ec2 describe-route-tables --filters "Name=tag:Name,Values=*isolated-db-rt*" trả về bảng chỉ có đúng 1 dòng: DestinationCidrBlock: 10.0.0.0/16 | GatewayId: local | State: active.
  - AWS Console: Bảng định tuyến prod-isolated-db-rt (gắn với 2 Isolated Subnets) chỉ hiển thị duy nhất 1 Route 10.0.0.0/16 -> local.

- Đánh giá: Chuẩn kiến trúc bảo mật. Chứng minh dữ liệu nhạy cảm được cách ly hoàn toàn ở tầng mạng vật lý, khô

Phase 2:

PHẦN 1: TỔNG KẾT TỔNG QUAN PHASE 2 (EXECUTIVE SUMMARY)

Phase 2 đã nâng cấp toàn diện hạ tầng từ giai đoạn tạo lập thủ công sang mô hình GitOps & DevSecOps chuẩn doanh nghiệp. Mục tiêu trọng tâm của phase này là xóa bỏ hoàn toàn rủi ro bảo mật thông tin xác thực tĩnh, đưa kiểm toán bảo mật về sát khâu phát triển (Shift-Left Security), và đạt được khả năng phát hành liên tục không gián đoạn dịch vụ (Zero-Downtime Deployment).

Kết quả:

- **Loại bỏ 100% Long-lived Credentials (Zero Static Secrets):** Không lưu trữ bất kỳ cặp AWS_ACCESS_KEY_ID hay AWS_SECRET_ACCESS_KEY nào trên GitHub Secrets. Việc xác thực giữa GitHub Actions và AWS hoàn toàn dựa trên cơ chế liên kết danh tính IAM OpenID Connect (OIDC) với phiên truy cập tạm thời cấp từ AWS STS.
- **Thiết lập rào chắn an ninh ca trái (Shift-Left Security Gate):** Kiểm soát nghiêm ngặt chất lượng mã nguồn hạ tầng và ứng dụng thông qua bộ ba công cụ: TFLint (chuẩn hóa cú pháp IaC), Checkov (quét tuân thủ CIS AWS Benchmark), và Trivy (quét lỗ hổng CVEs thư viện). Bất kỳ vi phạm bảo mật mức độ nghiêm trọng nào ở khâu Pull Request đều bị chặn tự động trước khi hòa nhập vào nhánh main.
- **Tự động hóa triển khai Rolling Update qua AWS CodeDeploy:** Tích hợp trực tiếp CodeDeploy với Auto Scaling Group và Application Load Balancer (ALB) của Phase 1. Chiến lược triển khai cuốn chiếu OneAtATime kết hợp cơ chế ngắt kết nối an toàn (Connection Draining) đảm bảo hệ thống phục vụ liên tục trong suốt quá trình cập nhật.
- **Cơ chế tự kiểm chứng tính toàn vẹn (Self-Probing):** Hook ValidateService kiểm tra trực tiếp endpoint /healthz tại cổng nội bộ của ứng dụng, chỉ cho phép Load Balancer điều phối lưu lượng đến máy chủ khi ứng dụng đã thực sự sẵn sàng.

- **Hiệu suất vận hành thực tế:** Đo lường 0% mã lỗi 5xx trong suốt quá trình triển khai mã nguồn mới (v2.0).

PHẦN 2: GIẢI THÍCH FULL TỪNG BƯỚC ĐÃ THỰC HIỆN

Quy trình triển khai Phase 2 được thực hiện theo 6 bước tuần tự, chặt chẽ:

[BƯỚC 1: IAM OIDC & S3 ARTIFACTS] —> [BƯỚC 2: CODEDEPLOY ASG & AGENT] —> [BƯỚC 3: CODEDEPLOY SPEC & HOOKS]

|

[BƯỚC 6: FAULT INJECTION & VERIFICATION] <— [BƯỚC 5: GITOPS PIPELINE] <— [BƯỚC 4: SHIFT-LEFT GATE]

Bước 1: Khởi tạo Identity Federation & S3 Artifact Storage (terraform/global/oidc.tf)

- **Mục đích:** Thiết lập cơ chế xác thực danh tính không mật khẩu và tạo không gian lưu trữ các gói phần mềm triển khai.
- **Thực thi:** Cấu hình OpenID Connect Provider trỏ đến token.actions.githubusercontent.com. Tạo IAM Role với Trust Policy ràng buộc điều kiện (Condition) nghiêm ngặt tới duy nhất repository chỉ định, đồng thời tạo S3 Bucket kích hoạt Versioning và mã hóa mặc định SSE-S3 để chứa các file nén artifact.

Bước 2: Tích hợp AWS CodeDeploy vào Auto Scaling Group & Cài đặt Agent

- **Mục đích:** Xây dựng cầu nối giữa hạ tầng tính toán (ASG) và hệ thống phân phối mã nguồn (CodeDeploy).
- **Thực thi:** Khởi tạo aws_codedeploy_app và aws_codedeploy_deployment_group với cấu hình triển khai CodeDeployDefault.OneAtATime. Bổ sung đoạn mã cài đặt tự động codedeploy-agent vào file user_data.sh của Launch Template và kích hoạt Instance Refresh để các máy ảo trong ASG nhận agent mới.

Bước 3: Đóng gói ứng dụng & Thiết kế Lifecycle Hooks (app/)

- **Mục đích:** Định nghĩa các giai đoạn thực thi chi tiết trên máy ảo khi đón nhận gói cập nhật mới.
- **Thực thi:** Viết file đặc tả appspec.yml cùng 4 script vòng đời: dừng service an toàn (before_install.sh), cài đặt thư viện production (after_install.sh), khởi động lại tiến trình qua systemd (start_server.sh), và kiểm tra sức khỏe cục bộ (validate_service.sh).

Bước 4: Thiết lập rào chắn kiểm thử an ninh tự động (iac-security-scan.yml)

- **Mục đích:** Ngăn ngừa việc đưa mã nguồn chứa lỗ hổng bảo mật vào nhánh chính của repository.
- **Thực thi:** Xây dựng workflow kích hoạt tự động mỗi khi có Pull Request mở vào nhánh main. Pipeline chạy đồng thời 3 tác vụ: TFLint kiểm tra cú pháp Terraform, Checkov quét cấu hình Security Group / VPC theo chuẩn CIS, và Trivy quét lỗ hổng các package trong package.json.

Bước 5: Xây dựng Pipeline phát hành tự động GitOps (release-deploy.yml)

- **Mục đích:** Tự động hóa chu trình từ khi merge code đến khi ứng dụng chạy thực tế trên các máy chủ EC2.
- **Thực thi:** Khi có commit đẩy vào nhánh main, runner GitHub Actions gửi yêu cầu lấy token ngắn hạn từ AWS STS thông qua IAM OIDC, nén mã nguồn thành file zip, tải lên S3 Artifact Bucket, gọi API tạo deployment trên AWS CodeDeploy và theo dõi tiến độ cho đến khi hoàn tất.

Bước 6: Diễn tập kiểm thử sự cố & Đo lường Rolling Deployment

- **Mục đích:** Xác minh độc lập các kịch bản kiểm thử:
    1. Kiểm tra log OIDC để chứng minh không có secret tĩnh được sử dụng.

2. Tạo branch vi phạm bảo mật (mở port 22 SSH) để chứng minh Checkov chặn thành công Pull Request.
3. Theo dõi bảng điều khiển CodeDeploy xác nhận 100% lifecycle hooks thành công.
4. Thực hiện nâng cấp giao diện ứng dụng lên v2.0 kết hợp chạy vòng lặp curl liên tục để đo lường tính sẵn sàng và tỷ lệ lỗi 5xx.

PHẦN 3: CẤU TRÚC CHI TIẾT TỪNG FILE MÃ NGUỒN VÀ Ý NGHĨA KỸ THUẬT

1. Tầng CI/CD Workflows (.github/workflows/)

- **.github/workflows/iac-security-scan.yml**:
  - *Ý nghĩa:* Rào chắn chất lượng và an ninh ca trái (Shift-Left Quality & Security Gate).
  - *Chi tiết kỹ thuật:*
    - Chạy độc lập trên môi trường ubuntu-latest mỗi khi có Pull Request trỏ vào nhánh main.
    - Tác vụ checkov-security-scan: Thiết lập tham số soft_fail: false nhằm trả về mã thoát (exit code) khác 0 nếu phát hiện vi phạm bảo mật mức cao, từ đó kích hoạt cơ chế khóa merge của GitHub.
    - Tác vụ trivy-dependency-scan: Sử dụng tham số severity: 'CRITICAL,HIGH' kết hợp exit-code: '1' để kiểm soát lỗ hổng từ chuỗi cung ứng phần mềm (Software Supply Chain).
- **.github/workflows/release-deploy.yml**:
  - *Ý nghĩa:* Quy trình phân phối mã nguồn và tự động hóa triển khai ứng dụng.

- *Chi tiết kỹ thuật:*
    - Khai báo quyền permissions: id-token: write cho phép GitHub Actions phát hành JSON Web Token (JWT) đã ký mã hóa.
    - Sử dụng action aws-actions/configure-aws-credentials@v4 kết hợp tham số role-to-assume, cho phép runner chuyển đổi JWT lấy credential tạm thời có hiệu lực 1 giờ từ AWS STS mà không chạm vào secret tĩnh.
    - Lệnh aws deploy create-deployment truyền trực tiếp địa chỉ file zip trên S3, chỉ định Deployment Group và gọi aws deploy wait deployment-successful để block job cho tới khi quá trình rolling update hoàn tất.

2. Tầng Hạ tầng Triển khai (terraform/)

- **terraform/global/oidc.tf**:
    - *Ý nghĩa:* Cung cấp nền tảng quản lý định danh liên kết và lưu trữ bản phát hành.
    - *Chi tiết kỹ thuật:*
        - Khối aws_iam_openid_connect_provider: Định danh máy chủ cấp phát danh tính của GitHub qua URL https://token.actions.githubusercontent.com.
        - Khối aws_iam_role.github_actions_deployer: Chứa Trust Policy với điều kiện StringLike: "token.actions.githubusercontent.com:sub": "repo:<owner>/<repo>:*". Ràng buộc này đảm bảo chỉ các workflow chạy đúng trong repository này mới có thể assume role, ngăn chặn việc giả mạo danh tính từ repo bên ngoài.
        - Khối aws_s3_bucket.codedeploy_artifacts: Lưu trữ các file nén revision ứng dụng, bật mã hóa SSE-S3 và chặn toàn bộ truy cập công khai.

- **terraform/modules/asg/codedeploy.tf**:
    - *Ý nghĩa:* Tích hợp dịch vụ CodeDeploy với cụm tính toán co giãn Auto Scaling Group.
    - *Chi tiết kỹ thuật:*
        - Cấp quyền dịch vụ AWSCodeDeployRole cho CodeDeploy thông qua aws_iam_role.codedeploy_service.
        - Cấu hình deployment_config_name = "CodeDeployDefault.OneAtATime": Triển khai lần lượt từng máy ảo để đảm bảo năng lực xử lý của hệ thống không bị suy giảm.
        - Khối load_balancer_info.target_group_info: CodeDeploy tự động gửi tín hiệu tới Target Group của ALB để drain kết nối trước khi cập nhật instance, sau đó tự đăng ký lại khi instance đã hoàn tất cập nhật.
        - Khối auto_rollback_configuration: Tự động quay về phiên bản trước nếu quá trình triển khai gặp lỗi, bảo vệ hệ sinh thái production.

3. Tầng Vòng đời Triển khai Ứng dụng (app/)

- **app/appspec.yml**:
    - *Ý nghĩa:* Bản đồ điều phối các hoạt động của CodeDeploy Agent trên từng máy ảo EC2.
    - *Chi tiết kỹ thuật:* Định nghĩa thư mục đích cài đặt (/opt/app), thiết lập quyền sở hữu ec2-user:ec2-user, và chỉ định thứ tự kích hoạt các lifecycle hooks theo quyền root.
- **app/scripts/before_install.sh**:
    - *Ý nghĩa:* Chuẩn bị filesystem và tạm dừng dịch vụ phiên bản cũ.
    - *Chi tiết kỹ thuật:* Tạo thư mục sao lưu (/opt/app_backup) phục vụ việc truy vết, đồng thời gọi systemctl stop cloud-app.service (graceful).
- **app/scripts/after_install.sh**:

    - *Ý nghĩa:* Cài đặt môi trường vận hành mã nguồn mới.
    - *Chi tiết kỹ thuật:* Thiết lập lại quyền chmod 755 cho thư mục mã nguồn và gọi sudo -u ec2-user npm install --production --no-audit để kéo chính xác các gói dependencies mà không cài đặt các package dev.
- **app/scripts/start_server.sh**:
    - *Ý nghĩa:* Khởi tạo tiến trình máy chủ.
    - *Chi tiết kỹ thuật:* Nạp lại cấu hình dịch vụ qua systemctl daemon-reload, sau đó khởi động và bật dịch vụ qua systemctl restart cloud-app.service.
- **app/scripts/validate_service.sh**:
    - *Ý nghĩa:* Tự kiểm tra sức khỏe ứng dụng trước khi trả quyền kiểm soát cho ALB.
    - *Chi tiết kỹ thuật:* Chạy vòng lặp thăm dò tối đa 12 lần (mỗi lần cách nhau 5 giây) gửi request HTTP GET tới http://127.0.0.1:8080/healthz. Nếu nhận phản hồi 200 OK, script lập tức trả về mã thành công; nếu sau 60 giây không đạt, script sẽ in 50 dòng log hệ thống gần nhất (journalctl) và trả về exit code 1 để kích hoạt rollback.

PHẦN 4: ĐÁNH GIÁ CHI TIẾT CÁC BẰNG CHỨNG THỰC NGHIỆM (PROOF OF WORK)

Bằng chứng 1: Xác thực Passwordless qua IAM OIDC (Scenario 1)

- Workflow: Production Release & Zero-Downtime Deployment #19.

- Bước thực thi: Authenticate to AWS via OIDC Federation.
- Log ghi nhận:
  - role-to-assume: arn:aws:iam::222634368199:role/github-actions-enterprise-deployer-role.
  - role-session-name: GitHubActions-EnterpriseDeployment.
  - audience: sts.amazonaws.com.
  - Assuming role with OIDC.
  - Authenticated as assumedRoleId AROATHVQK3TDZQPSJJAA:GitHubActions-EnterpriseDeployment.

- **Đánh giá:** Chuẩn Zero-Trust. Quá trình xác thực diễn ra thành công trong vòng 1 giây. Hoàn toàn không phát sinh việc lưu trữ Access Key/Secret Key tĩnh trên GitHub, triệt tiêu nguy cơ rò rỉ secret quản trị đám mây.

Bằng chứng 2: Rào chắn Shift-Left chặn Pull Request vi phạm bảo mật (Scenario 2)

- Workflow: Security & CIS Compliance Scan (Checkov).
- Kết quả: Đánh dấu thất bại (Fail - dấu X đỏ).
- Báo cáo chi tiết:
  - Check: CKV_AWS_24: "Ensure no security groups allow ingress from 0.0.0.0:0 to port 22".
  - FAILED for resource: module.security_groups.aws_security_group.app.
  - Chỉ ra chính xác dòng vi phạm: Dòng 44–50 mở cổng 22 từ CIDR 0.0.0.0/0 với ghi chú "Insecure SSH access from anywhere".

- **Đánh giá:** Pipeline đã phát hiện lỗ hổng cấu hình hạ tầng ngay từ tầng Pull Request, chủ động ngăn chặn việc đưa cấu hình mất an toàn lên môi trường production.

Bằng chứng 3: Thực thi thành công toàn bộ CodeDeploy Lifecycle Events (Scenario 3)

    - Bảng điều khiển CodeDeploy ghi nhận phiên triển khai:
        - Instance: i-03d0b12b2739a38f4 tại ap-southeast-1.
        - Application: prod-enterprise-app | Deployment Group: prod-enterprise-asg-dg.
        - Deployment ID: d-W3Q3DFOOL | Deployment configuration: CodeDeployDefault.OneAtATime.
        - Revision Location: s3://enterprise-codedeploy-artifacts-apse1-222634368199/revisions/deployment-...zip.
        - Trạng thái chung: Succeeded.
    - Bảng tiến trình chi tiết các Lifecycle Hooks:
        - ApplicationStop: Succeeded (< 1s).
        - DownloadBundle: Succeeded (< 1s).
        - BeforeInstall: Succeeded (< 1s).
        - Install: Succeeded (< 1s).
        - AfterInstall: Succeeded (1s).
        - ApplicationStart: Succeeded (< 1s).
        - ValidateService: Succeeded (< 1s).
- **Đánh giá:** Toàn bộ chuỗi hook cài đặt, cấp quyền, cấu hình và thăm dò sức khỏe hoạt động tuần tự và thành công trọn vẹn.

Bằng chứng 4: Triển khai Rolling Update Zero-Downtime thực tế (Scenario 4)

- Mã nguồn ứng dụng tại server.js được cập nhật phiên bản mới: <h1> AWS Enterprise 3-Tier Diagnostic Hub v2.0</h1>.
- Terminal giám sát lưu lượng qua vòng lặp liên tục:

while true; do curl -s -o /dev/null -w "%{http_code} - %{time_total}s\n" http://$ALB_URL/healthz; sleep 0.5; done

- Kết quả trả về thực tế:
  - 200 - 0.071995s
  - 200 - 0.094328s
  - 200 - 0.088567s
  - .....

- **Đánh giá:** Chứng nhận độ sẵn sàng cao (High Availability). 100% request duy trì trạng thái 200 OK với độ trễ trung bình cực thấp (~70–100ms). Tỷ lệ lỗi 5xx là 0.0%, chứng minh việc kết hợp ALB Connection Draining và CodeDeploy rolling update đã triệt tiêu hoàn toàn hiện tượng nghẽn hay rớt kết nối khi nâng cấp ứng dụng.

Phase 3:

PHẦN 1: TỔNG KẾT TỔNG QUAN PHASE 3 (EXECUTIVE SUMMARY)

Phase 3 đã nâng cấp toàn diện hạ tầng từ giai đoạn tự động hóa triển khai (GitOps CI/CD ở Phase 2) lên cấp độ Production Observability & SRE Incident Response chuẩn doanh nghiệp. Thay vì giám sát thụ động (Monitoring), hệ thống đã đạt được năng lực quan sát chủ động toàn diện (Observability) dựa trên 4 Tín hiệu Vàng (The Four Golden Signals: Latency, Traffic, Errors, Saturation) theo chuẩn Google Site Reliability Engineering (SRE).

Kết quả:

- Xóa bỏ "điểm mù ảo hóa" với Host-Level Telemetry: Triển khai CloudWatch Unified Agent trên toàn bộ cụm máy chủ EC2 Graviton, thu thập trực tiếp số đo RAM vật lý (mem_used_percent) và phân vùng ổ đĩa (disk_used_percent) — những chỉ số mà Hypervisor mặc định của AWS EC2 không thể can thiệp do rào cản cô lập phần cứng.
- Quản trị giám sát dưới dạng mã nguồn (Dashboard-as-Code): Khởi tạo một màn hình điều khiển tập trung (Single Pane of Glass) Enterprise-Primary-Observability-Hub hoàn toàn bằng Terraform. Bảng điều khiển này hợp nhất luồng số đo từ ALB, EC2, RDS Multi-AZ và Synthetic Canary trong thời gian thực.
- Phân tích log và chuyển đổi số đo theo thời gian thực (Log Metric Filters): Gom toàn bộ log ứng dụng và hệ thống vào CloudWatch Log Group /aws/ec2/enterprise-app, tự động phân tích và chuyển đổi các ngoại lệ HTTP 500 thành số đo định lượng Error500Count trong namespace tùy chỉnh CustomApp/Diagnostics.
- Giám sát ngoài luồng độc lập (Outside-In Synthetic Monitoring): Triển khai CloudWatch Synthetics Canary sử dụng headless browser Puppeteer

gửi gói tin kiểm tra nhịp tim (Heartbeat) định kỳ 60 giây một lần tới endpoint /healthz, đảm bảo tính khả dụng của dịch vụ được đo lường chính xác từ góc nhìn của người dùng Internet.

- Định tuyến sự cố tự động (Incident Routing & ChatOps): Cấu hình Amazon SNS Topic điều phối cảnh báo tức thời tới Email quản trị viên và kênh vận hành (Slack/Discord) ngay khi các ngưỡng SLO/SLA bị vi phạm (High CPU > 80%, Lỗi 500 >= 3, Canary drop < 100%).
- Quy trình ứng cứu sự cố chuẩn hóa (SRE Runbook): Ban hành tài liệu incident-runbook.md phân cấp mức độ nghiêm trọng (SEV-1 đến SEV-3) cùng các quy trình thao tác chuẩn (SOPs) giúp kỹ sư trực ca cô lập và khắc phục sự cố nhanh chóng.

PHẦN 2: GIẢI THÍCH FULL TỪNG BƯỚC ĐÃ THỰC HIỆN

Quy trình triển khai Phase 3 tuân thủ nghiêm ngặt 7 bước kỹ thuật:

[BƯỚC 1: HOST TELEMETRY CW AGENT] —> [BƯỚC 2: ALB METRIC OUTPUTS] —> [BƯỚC 3: LOG GROUP & METRIC FILTERS]

|

[BƯỚC 7: FAULT INJECTION & VERIFICATION] <— [BƯỚC 6: SRE RUNBOOK] <— [BƯỚC 5: DASHBOARD & ALARMS] <— [BƯỚC 4: SYNTHETICS CANARY]

Bước 1: Kích hoạt Host-Level Telemetry qua CloudWatch Unified Agent

- **Mục đích:** Khắc phục hạn chế của số đo EC2 mặc định (chỉ thấy CPU và Network, không thấy RAM/Disk).
- **Thực thi:** Cập nhật script user_data.sh cài đặt amazon-cloudwatch-agent, tạo file cấu hình /opt/aws/amazon-cloudwatch-agent/bin/config.json định kỳ mỗi 60 giây thu thập mem_used_percent, disk_used_percent và gom file log hệ thống đẩy về CloudWatch Logs.

Bước 2: Bổ sung định danh số đo cho Application Load Balancer

- **Mục đích:** CloudWatch Metrics yêu cầu chuỗi định danh chiều không gian cụ thể (LoadBalancer và TargetGroup dimension) để lọc dữ liệu lưu lượng.
- **Thực thi:** Cập nhật terraform/modules/alb/outputs.tf xuất 2 giá trị cốt lõi: alb_arn_suffix và target_group_arn_suffix.

Bước 3: Thiết lập Log Group và bộ lọc số đo thời gian thực (metric_filters.tf)

- **Mục đích:** Phát hiện và lượng hóa các lỗi runtime phát sinh từ ứng dụng.
- **Thực thi:** Tạo CloudWatch Log Group /aws/ec2/enterprise-app với thời gian lưu trữ 7 ngày. Khởi tạo aws_cloudwatch_log_metric_filter quét mẫu chuỗi log chứa Simulated Fatal Exception hoặc mã lỗi 500, ánh xạ thành số đếm tăng dần Error500Count trong namespace CustomApp/Diagnostics.

Bước 4: Xây dựng giải pháp giám sát ngoài luồng (canary.tf)

- **Mục đích:** Giám sát liên tục tính sẵn sàng của hệ thống từ bên ngoài AWS.
- **Thực thi:** Tạo S3 Bucket lưu trữ artifact/screenshots của canary, cấp IAM Execution Role cho Lambda/Synthetics, đóng gói inline script Node.js Puppeteer và tạo aws_synthetics_canary chạy với chu kỳ rate(1 minute).

Bước 5: Định nghĩa Dashboard-as-Code và hệ thống cảnh báo sự cố (main.tf)

- **Mục đích:** Trực quan hóa toàn bộ hạ tầng trên một màn hình và thiết lập cơ chế kích hoạt báo động.
- **Thực thi:** Tạo aws_sns_topic đăng ký gửi email cảnh báo, tạo 3 aws_cloudwatch_metric_alarm (High CPU, HTTP 500, Canary Availability), và viết khối JSON cấu hình aws_cloudwatch_dashboard với 5 widgets đại diện cho 4 tín hiệu vàng.

Bước 6: Điều phối môi trường chính & Ban hành tài liệu SRE Runbook

- **Mục đích:** Kích hoạt toàn bộ module giám sát vào primary-singapore và xây dựng tài liệu chuẩn cho đội ngũ vận hành.
- **Thực thi:** Gọi module observability trong environments/primary-singapore/main.tf, chạy terraform apply, xác nhận subscription email SNS, và hoàn thiện tài liệu docs/incident-runbook.md.

Bước 7: Kích hoạt sự cố giả lập (Fault Injection) và thu thập minh chứng

- **Mục đích:** Kiểm chứng tính chính xác và độ nhạy của hệ thống cảnh báo.
- **Thực thi:**
    1. Truy cập CloudWatch Console kiểm tra Dashboard-as-Code.
    2. Bấm nút "Simulate HTTP 500" (/api/simulate-500) liên tục để kiểm tra Metric Filter và Alarm lỗi 500.
    3. Kiểm tra kết quả thực thi của Synthetic Canary (Success Rate 100%).
    4. Bấm nút "Trigger CPU Stress" (/api/stress-cpu) làm CPU vọt lên >80%, kích hoạt Alarm chuyển sang trạng thái đỏ và nhận email cảnh báo.

PHẦN 3: CẤU TRÚC CHI TIẾT TỪNG FILE MÃ NGUỒN VÀ Ý NGHĨA KỸ THUẬT

1. File cấu hình Agent: app/scripts/user_data.sh

- **Ý nghĩa:** Khởi tạo môi trường thu thập số đo chuyên sâu trực tiếp từ nhân Linux của máy chủ EC2.
- **Chi tiết kỹ thuật:**

- Lệnh cài đặt gói RPM chính chủ: dnf install -y amazon-cloudwatch-agent.
- Khối cấu hình JSON: Khai báo namespace CWAgent, thiết lập tần suất lấy mẫu 60 giây cho mem_used_percent và disk_used_percent trên phân vùng gốc /.
- Khối append_dimensions: Gắn nhãn AutoScalingGroupName và InstanceId vào từng metric, cho phép CloudWatch Dashboard gom nhóm số đo tài nguyên theo cụm ASG.
- Khối logs_collected: Thu thập file /var/log/messages và stream trực tiếp về CloudWatch Log Group.

2. File mở rộng Load Balancer: terraform/modules/alb/outputs.tf

- **Ý nghĩa:** Cung cấp định danh chiều không gian cho các câu truy vấn CloudWatch Metrics.
- **Chi tiết kỹ thuật:** Xuất thuộc tính alb_arn_suffix (dạng app/prod-public-alb/...) và target_group_arn_suffix (dạng targetgroup/prod-app-tg/...). Đây là định dạng bắt buộc trong trường dimensions của metric AWS/ApplicationELB (RequestCount, TargetResponseTime, HTTPCode_Target_5XX_Count).

3. Module Observability (terraform/modules/observability/)

- **metric_filters.tf**:
  - *Ý nghĩa:* Xử lý dữ liệu phi cấu trúc (log text) thành dữ liệu số có cấu trúc (metrics) mà không tốn tài nguyên tính toán của máy chủ.
  - *Chi tiết kỹ thuật:* Khởi tạo Log Group với vòng đời lưu trữ 7 ngày (retention_in_days = 7) nhằm tối ưu chi phí. aws_cloudwatch_log_metric_filter sử dụng filter pattern tìm kiếm chuỗi lỗi ngoại lệ và tăng giá trị metric Error500Count lên 1 đơn vị cho mỗi lần phát hiện.
- **canary.tf**:

- *Ý nghĩa:* Tự động hóa kiểm thử tính sẵn sàng liên tục từ góc nhìn người dùng cuối (Outside-In Availability Probing).
- *Chi tiết kỹ thuật:*
  - Khối aws_s3_bucket.canary_artifacts: Lưu trữ file log, kết quả request và ảnh chụp màn hình (screenshot) sau mỗi lần chạy probe.
  - Khối aws_iam_role.canary_role: Cấp quyền tối thiểu cho hàm Lambda chạy ngầm của Canary để ghi log, đưa dữ liệu vào namespace CloudWatchSynthetics và tải artifact lên S3.
  - Khối aws_synthetics_canary.app_canary: Sử dụng runtime syn-nodejs-puppeteer-9.1 thực thi script Node.js HTTP Step, gửi request tới /healthz mỗi 60 giây và kích hoạt ngoại lệ nếu mã phản hồi khác 200.

- **main.tf**:
  - *Ý nghĩa:* Trung tâm điều phối cảnh báo sự cố và giao diện trực quan hóa hạ tầng.
  - *Chi tiết kỹ thuật:*
    - aws_sns_topic.alerts: Kênh truyền thông báo sự cố tập trung tới email quản trị viên.
    - 3 aws_cloudwatch_metric_alarm:
      - high_cpu: Theo dõi AWS/EC2/CPUUtilization trên cụm ASG, kích hoạt khi vượt quá 80% trong 2 chu kỳ đánh giá (2 datapoints within 2 minutes).
      - http_500: Theo dõi CustomApp/Diagnostics/Error500Count, kích hoạt khi tổng số lỗi >= 3 trong 1 phút.
      - canary_failure: Theo dõi CloudWatchSynthetics/SuccessPercent, kích hoạt khi tính sẵn sàng sụt giảm dưới 100%.
    - aws_cloudwatch_dashboard.main: Thiết kế dạng JSON gồm 5 widgets trực quan: lưu lượng truy cập/mã phản hồi ALB, độ trễ p95 ALB, độ bão hòa CPU/RAM EC2, kết nối/CPU cơ

sở dữ liệu RDS, và tính sẵn sàng/độ trễ của Synthetic Canary.

4. Tài liệu Vận hành SRE: docs/incident-runbook.md

- **Ý nghĩa:** Chuẩn hóa quy trình xử lý sự cố cho kỹ sư trực ca (On-Call Engineer), giảm thiểu thời gian trung bình để phục hồi hệ thống (MTTR - Mean Time To Recovery).
- **Chi tiết kỹ thuật:**
    - Bảng phân cấp sự cố: Phân định rõ SEV-1 (Sự cố tê liệt dịch vụ, SLA phản hồi < 15 phút), SEV-2 (Hiệu năng suy giảm/CPU cao, SLA < 30 phút), SEV-3 (Cảnh báo dung lượng, SLA < 2 giờ).
    - 3 quy trình chuẩn (SOP-01, SOP-02, SOP-03): Mô tả chi tiết triệu chứng nhận diện, các bước chẩn đoán bằng CloudWatch Dashboard/Log Insights/SSM CLI, và phương án khắc phục tương ứng cho từng loại sự cố.

PHẦN 4: ĐÁNH GIÁ CHI TIẾT CÁC BẰNG CHỨNG THỰC NGHIỆM (PROOF OF WORK)

Toàn bộ các bằng chứng thực nghiệm trong Phase 3 đã được ghi nhận trực tiếp từ hệ thống AWS Console và dịch vụ cảnh báo:

Bằng chứng 1: Kiểm chứng CloudWatch Dashboard-as-Code (Scenario 1)

- **Phân tích hình ảnh thực tế từ AWS Console:**
    - Tên Dashboard: **Enterprise-Primary-Observability-Hub**.
    - Bảng điều khiển tích hợp đồng bộ 5 widgets đại diện cho 4 tín hiệu vàng:

1. **ALB Ingress Traffic & Response Status Codes:** Hiển thị rõ biểu đồ đường của RequestCount (đỉnh đạt 4 requests), HTTPCode_Target_2XX_Count (đường xanh lá), và HTTPCode_Target_5XX_Count (đường đỏ).
2. **ALB Target Latency (p95 Round-Trip Time):** Ghi nhận các điểm đo độ trễ p95 khi có request với thời gian phản hồi từ 62.7 ms đến 124.3 ms.
3. **EC2 ASG Resource Saturation (CPU vs Memory):** Thể hiện rõ số đo RAM vật lý CWAgent mem_used_percent đạt đỉnh ~12% trước khi ổn định ở mức ~6.33%, kết hợp cùng đường AWS/EC2 CPUUtilization.
4. **Amazon RDS Multi-AZ Active Connections & CPU:** Ghi nhận số lượng kết nối cơ sở dữ liệu DatabaseConnections duy trì liên tục, CPU cơ sở dữ liệu ổn định mức thấp sau đợt kết nối ban đầu (giảm từ 44.47% về mức ổn định).
5. **Synthetic Canary Availability:** Đường đo tỷ lệ thành công SuccessPercent đạt mức tuyệt đối 100%, kết hợp với trục phụ đo thời gian thực thi Duration từ 44ms đến 1.2s.

- **Đánh giá:** Bảng điều khiển thể hiện đầy đủ bức tranh vận hành toàn diện của cả 3 tầng (Network, Compute, Database) và kiểm thử ngoài luồng, chứng minh toàn bộ hạ tầng Dashboard được dựng chính xác 100% bằng Terraform.

Bằng chứng 2: Bắt lỗi Runtime qua Log Metric Filter & Gửi cảnh báo tức thời (Scenario 2)

- **Phân tích hình ảnh thực tế:**
  - **Email cảnh báo từ AWS SNS:**
    - Người gửi: AWS Notifications <no-reply@sns.amazonaws.com>.
    - Tiêu đề: ALARM: "prod-Enterprise-App-High500Errors-Alarm" in Asia Pacific (Singapore).

        - Nội dung xác nhận: Threshold Crossed: 1 datapoint [8.0 (12/10/26 20:35:00)] was greater than or equal to the threshold (3.0).
        - Thời gian kích hoạt: Monday 12 October, 2026 20:36:59 UTC.
        - AWS Account ID: 222634368199.
        - MetricNamespace: CustomApp/Diagnostics | MetricName: Error500Count.
    - **Giao diện CloudWatch Alarms:**
        - Báo động prod-Enterprise-App-High500Errors-Alarm chuyển sang trạng thái màu đỏ rực: In alarm.
        - Biểu đồ số đo ghi nhận: Error500Count vọt lên mức 8 (vượt xa ngưỡng đỏ Error500Count >= 3 for 1 datapoints within 1 minute).
- **Đánh giá:**.Ứng dụng khi bị lỗi 500 đã được CloudWatch Log Group bắt trọn, Metric Filter lượng hóa thành công số lượng lỗi theo thời gian thực và kích hoạt gửi email cảnh báo tự động trong vòng chưa đầy 60 giây.

Bằng chứng 3: Giám sát ngoài luồng với CloudWatch Synthetics Canary (Scenario 3)

- **Phân tích hình ảnh thực tế từ Console:**
    - Canary Identifier: app-health-canary.
    - Thông báo trạng thái tổng quan: "Your canary completed 60 runs across 1 locations in the past 1 hour, with a 100% success rate.".
    - Biểu đồ Canary run duy trì một đường ngang tuyệt đối ở mức 100% Success Rate.
    - Chi tiết lần chạy gần nhất (Oct 12, 2026 20:43:33):
        - Trạng thái: Passed (màu xanh lá).
        - Thời gian thực thi toàn bộ luồng probe: 0.6 s.

        - Tab HTTP requests: Gửi probe tới endpoint http://prod-public-alb-89258298.ap-southeast-...**/healthz**, mã phản hồi trả về 200 OK, thời gian phản hồi cực nhanh chỉ 6 ms.
- **Đánh giá:** Khẳng định năng lực giám sát chủ động (Proactive Probing) hoạt động ổn định, độc lập hoàn toàn với trạng thái nội bộ của máy chủ, cung cấp chỉ số độ sẵn sàng SLA/SLO chân thực nhất.

Bằng chứng 4: Quá tải CPU giả lập & Kích hoạt High CPU Alarm (Scenario 4)

- **Phân tích hình ảnh thực tế:**
    - Alarm Identifier: prod-Enterprise-App-HighCPU-Alarm.
    - Trạng thái: In alarm (màu đỏ).
    - Quy tắc kích hoạt: CPUUtilization > 80 for 2 datapoints within 2 minutes (80).
    - Biểu đồ phân tích: Đường số đo CPU Utilization của máy chủ bật tăng dốc đứng từ mức bình thường (~0.67%) vọt thẳng qua đường ngưỡng đỏ 80%.
    - Chi tiết đối tượng bị ảnh hưởng: Gắn chính xác vào Auto Scaling Group prod-asg-20261012191008404000000000f.
    - Thời điểm cập nhật trạng thái: 2026-10-12 21:33:29 (UTC).
- **Đánh giá:** Kịch bản Stress Testing đã kích hoạt thành công cơ chế phát hiện suy giảm tài nguyên (Saturation). Cảnh báo phản ứng nhạy bén, liên kết trực tiếp tới quy trình khắc phục trong Runbook docs/incident-runbook.md#high-cpu

Phase 4:

PHẦN 1: TỔNG KẾT TỔNG QUAN PHASE 4 (EXECUTIVE SUMMARY)

Phase 4 đã chuyển đổi nền tảng từ một hệ thống có tính sẵn sàng cao (High Availability) và giám sát tập trung (Observability) sang một kiến trúc được tăng cường bảo mật chuyên sâu (Security Hardening) và thiết lập ranh giới tuân thủ chuẩn doanh nghiệp (Compliance Baseline) theo tiêu chuẩn quốc tế CIS AWS Foundations Benchmark v1.4.0.

- Kết quả:

- **Phòng thủ chu vi Layer 7 (Perimeter Edge Defense):** Tích hợp trực tiếp AWS WAF v2 vào Application Load Balancer (ALB), ngăn chặn các mối đe dọa trong danh mục OWASP Top 10 (SQL Injection, Cross-Site Scripting, Command Injection) và kiểm soát lưu lượng chống tấn công từ chối dịch vụ (Layer 7 Anti-DDoS) thông qua luật Rate-Based.
- **Mã hóa lưu trữ tĩnh bằng Customer Managed Key (KMS CMK):** Thay thế toàn bộ các khóa mã hóa mặc định dùng chung của AWS bằng một khóa tùy chỉnh riêng biệt chuẩn AES-256 (CMK), bảo vệ phân vùng ổ đĩa Amazon EBS (máy ảo EC2 Graviton) và cơ sở dữ liệu Amazon RDS Multi-AZ PostgreSQL với chính sách tự động xoay vòng khóa hàng năm.

- **Tự động hóa vòng đời dữ liệu xác thực (Automated Secrets Life-Cycle):** Kích hoạt cơ chế tự động xoay vòng mật khẩu cơ sở dữ liệu trên AWS Secrets Manager theo chu kỳ 30 ngày thông qua một hàm AWS Lambda chuyên dụng, giảm thiểu rủi ro lộ lọt thông tin xác thực quản trị.
- **Định tuyến dữ liệu riêng biệt qua mạng trục AWS (Gateway VPC Endpoint):** Thiết lập VPC Endpoint cho Amazon S3, điều hướng toàn bộ lưu lượng đọc/ghi file nén artifact và log hệ thống đi trực tiếp trong mạng nội bộ AWS, loại bỏ hoàn toàn chi phí xử lý dữ liệu qua NAT Gateway và triệt tiêu nguy cơ rò rỉ dữ liệu qua Internet công cộng.
- **Xác thực và rà soát an toàn thông tin độc lập:** Kiểm toán hạ tầng đạt mức tuân thủ cao (> 90%) dựa trên bảng đối chiếu các điều khoản kỹ thuật của chuẩn CIS Benchmark.

PHẦN 2: GIẢI THÍCH FULL TỪNG BƯỚC ĐÃ THỰC HIỆN

Quy trình triển khai Phase 4 tuân thủ nghiêm ngặt 6 bước kỹ thuật theo mô hình Phòng thủ đa tầng (Defense-in-Depth):

[BƯỚC 1: KMS CMK & KEY POLICY] —> [BƯỚC 2: WAF v2 & RATE LIMIT] —> [BƯỚC 3: S3 GATEWAY ENDPOINT]

|

[BƯỚC 6: PEN-TEST & VERIFICATION] <— [BƯỚC 5: PLUG & PLAY WIRES] <— [BƯỚC 4: SECRETS AUTO-ROTATION]

Bước 1: Khởi tạo Customer Managed Key (CMK) trong AWS KMS (kms.tf)

- **Mục đích:** Đảm bảo quyền kiểm soát mã hóa dữ liệu độc lập của doanh nghiệp.
- **Thực thi:** Tạo khóa mã hóa đối xứng (SYMMETRIC_DEFAULT) kèm bí danh alias/prod-enterprise-cmk, kích hoạt enable_key_rotation = true (xoay vòng sau mỗi 365 ngày). Cấu hình Key Policy cấp quyền kms:CreateGrant và kms:GenerateDataKey* cho AWSServiceRoleForAutoScaling để Auto

Scaling Group có thể tự động tạo máy ảo với EBS volume được mã hóa mà không bị lỗi cấp quyền.

Bước 2: Thiết lập Tường lửa Ứng dụng Web AWS WAF v2 (waf.tf)

- **Mục đích:** Chặn đứng các payload tấn công web application ngay tại biên trước khi tới EC2.
- **Thực thi:** Khởi tạo Web ACL phạm vi Regional với hành động mặc định là Allow. Nhúng 3 bộ Managed Rules chính chủ từ AWS (CommonRuleSet, KnownBadInputsRuleSet, SQLiRuleSet) cùng 1 bộ luật tùy chỉnh RateLimit300RequestsPer5Minutes (tự động khóa IP nếu gửi quá 300 requests trong 5 phút).

Bước 3: Triển khai Gateway VPC Endpoint cho S3 (vpc_endpoints.tf)

- **Mục đích:** Định tuyến lưu lượng S3 nội bộ và tối ưu hóa chi phí đường truyền.
- **Thực thi:** Tạo VPC Endpoint loại Gateway trỏ tới dịch vụ com.amazonaws.ap-southeast-1.s3, gắn trực tiếp vào toàn bộ các Route Table (Public Route Table và Private Route Tables) của VPC đã tạo ở Phase 1.

Bước 4: Thiết lập Lambda xoay vòng mật khẩu Database (secrets_rotation.tf)

- **Mục đích:** Tuân thủ chuẩn an toàn thông tin về việc làm mới mật khẩu định kỳ.
- **Thực thi:** Cấp IAM Role cho Lambda có quyền truy cập VPC nội bộ và thao tác với Secrets Manager. Đóng gói mã nguồn Python thực thi 4 bước xoay vòng (createSecret, setSecret, testSecret, finishSecret), cấp quyền lambda:InvokeFunction cho dịch vụ Secrets Manager, và kích hoạt aws_secretsmanager_secret_rotation theo chu kỳ 30 ngày.

Bước 5: Đấu nối "Plug & Play" vào các module hiện có (main.tf)

- **Mục đích:** Áp dụng các chính sách bảo mật mới vào hạ tầng mà không phá vỡ kiến trúc sẵn có.
- **Thực thi:**
    - Truyền kms_key_arn vào module.rds (storage_encrypted = true).
    - Truyền kms_key_arn vào Launch Template trong module.asg để mã hóa phân vùng ổ đĩa root /dev/xvda.
    - Truyền waf_acl_arn vào module.alb để kích hoạt liên kết Web ACL với Public ALB qua chân cắm mở sẵn từ Phase 1.

Bước 6: Diễn tập kiểm thử an ninh & Bắn phá giả lập (Verification & Attack Simulation)

- **Mục đích:** Xác minh độc lập các cơ chế phòng thủ:
    1. Gửi payload SQL Injection và Cross-Site Scripting (XSS) kiểm tra phản hồi HTTP 403 từ WAF.
    2. Bắn burst requests tần suất cao để kiểm tra cơ chế chặn Layer 7 DDoS / Rate Limiting.
    3. Kiểm tra thuộc tính mã hóa của RDS và EBS bằng AWS CLI.
    4. Kiểm tra cấu hình xoay vòng mật khẩu của Secrets Manager qua CLI và Console.

PHẦN 3: CẤU TRÚC CHI TIẾT TỪNG FILE MÃ NGUỒN VÀ Ý NGHĨA KỸ THUẬT

1. Tầng Quản trị Khóa Mật mã: terraform/modules/security/kms.tf

- **Ý nghĩa:** Điểm cốt lõi đảm bảo an toàn cho dữ liệu tĩnh (Data at Rest).
- **Chi tiết kỹ thuật:**
    - Khối aws_kms_key.main: Thiết lập thời gian chờ hủy khóa 7 ngày (deletion_window_in_days = 7) phòng ngừa trường hợp xóa

nhầm, đồng thời bật cờ enable_key_rotation = true đáp ứng điều khoản CIS 2.8.

- Key Policy: Tách biệt rõ ràng quyền quản trị của tài khoản root với quyền sử dụng khóa của các service roles. Khối cấp quyền cho AWSServiceRoleForAutoScaling sử dụng điều kiện Condition = { Bool = { "kms:GrantIsForAWSResource" = "true" } }, đảm bảo chỉ các tài nguyên AWS hợp lệ trong tài khoản mới được cấp grant giải mã ổ đĩa.

2. Tầng Tường lửa Chu vi: terraform/modules/security/waf.tf

- **Ý nghĩa:** Lá chắn tầng 7 lọc bỏ lưu lượng độc hại từ Internet.
- **Chi tiết kỹ thuật:**
  - Các khối managed_rule_group_statement: Lần lượt gán thứ tự ưu tiên (Priority 1 đến 3) cho Common Rule Set, Bad Inputs, và SQLi Rule Set.
  - Khối rate_based_statement: Đặt Priority 4 với hạn mức limit = 300 và aggregate_key_type = "IP". Khi một IP vượt ngưỡng, WAF sẽ chuyển trạng thái của IP đó vào danh sách block tạm thời.
  - Mỗi rule đều được gán visibility_config riêng để đẩy số đo về CloudWatch Metrics, phục vụ việc giám sát số lượng request bị chặn theo từng loại tấn công.

3. Tầng Tối ưu Mạng & Cô lập: terraform/modules/security/vpc_endpoints.tf

- **Ý nghĩa:** Thiết lập tuyến kết nối riêng biệt cho lưu lượng lưu trữ đối tượng.
- **Chi tiết kỹ thuật:** Khởi tạo Endpoint loại Gateway kết nối trực tiếp với S3. Cơ chế Gateway chỉnh sửa trực tiếp các bảng định tuyến (Route Tables) trong VPC: khi máy ảo gửi request đến dải IP công khai của S3, gói tin sẽ được định tuyến trực tiếp qua card mạng ảo của endpoint thay vì đi qua NAT Gateway, giữ toàn bộ lưu lượng bên trong mạng riêng của AWS.

4. Tầng Xoay vòng Bí mật: terraform/modules/security/secrets_rotation.tf

- **Ý nghĩa:** Tự động hóa hoàn toàn quy trình làm mới thông tin xác thực quản trị.
- **Chi tiết kỹ thuật:**
    - Khối aws_lambda_function: Khởi tạo hàm xử lý đặt trong các Private Subnets của VPC, gán vào App Security Group để có đường truyền nội bộ tới cổng 5432 của PostgreSQL.
    - Khối aws_secretsmanager_secret_rotation: Thiết lập quy tắc automatically_after_days = 30, tự động gọi Lambda định kỳ để cập nhật mật khẩu trên cả database và Secrets Manager mà không làm gián đoạn ứng dụng.

5. Cập nhật Đấu nối Module: terraform/modules/asg/ & terraform/modules/rds/

- **modules/asg/main.tf**: Khối block_device_mappings chỉ định rõ encrypted = true và kms_key_id = var.kms_key_arn. Mọi volume EBS gốc gắn vào máy ảo EC2 Graviton khi scale out đều được mã hóa bằng CMK ngay từ thời điểm tạo.
- **modules/rds/main.tf**: Khai báo kms_key_id = var.kms_key_arn và storage_encrypted = true. Toàn bộ dữ liệu bảng, bản sao lưu (backups) và snapshot của cụm PostgreSQL Multi-AZ đều được bảo vệ dưới khóa CMK chuyên dụng.

PHẦN 4: ĐÁNH GIÁ CHI TIẾT CÁC BẰNG CHỨNG THỰC NGHIỆM (PROOF OF WORK)

Toàn bộ các bằng chứng thực nghiệm trong Phase 4 đã được ghi nhận trực quan qua các cuộc kiểm thử xâm nhập giả lập và bảng điều khiển AWS Console:

Bằng chứng 1: Kiến trúc Tầng Bảo mật Chuyên sâu (Architectural Scope)

- **Phân tích hình ảnh thực tế:**
    - Sơ đồ cắt riêng khối Phase 4: Security Hardening & Compliance thể hiện kiến trúc phòng thủ theo chiều sâu:
        - Phía trước ALB là AWS WAF v2 (Rate Limiting, Managed Rules).
        - Lõi dữ liệu được bao bọc bởi AWS KMS (CMK Encryption) và AWS Secrets Manager kết hợp Lambda Rotation.
        - Tầng truyền tải ngầm sử dụng VPC Gateway Endpoint for S3.
        - Tầng kiểm soát tuân thủ và phát hiện mối đe dọa liên kết với GuardDuty, Security Hub, và AWS Config Rules.
- **Đánh giá:** Đáp ứng đầy đủ các tiêu chuẩn kỹ thuật đề ra trong tài liệu thiết kế.

Bằng chứng 2: WAF Chặn Đứng Tấn công SQLi & XSS Tại Biên (Scenario 1)

- **Phân tích hình ảnh thực tế:**
    - **Thực thi trên Terminal:**
        - Lệnh gửi payload XSS: curl -i -s "http://$ALB_URL/?search=<script>alert('xss')</script>".
        - Kết quả phản hồi: HTTP/1.1 403 Forbidden.
        - Server định danh: awselb/2.0.
        - Thời gian ghi nhận: Wed, 14 Oct 2026 04:10:55 GMT.
    - **Giao diện AWS WAF Console (prod-alb-waf-web-acl):**
        - Bảng tổng quan (Summary): Ghi nhận rõ tổng số 5 requests, trong đó có 2 requests bị BLOCKED và 3 requests được ALLOWED.
        - Bảng Sampled requests ghi nhận chi tiết:
            - Request 1: URI /?search=<script>alert('xss')</script> xuất phát từ IP 203.210.242.203 (VN) bị chặn bởi rule

AWS#AWSManagedRulesCommonRuleSet#... với Action BLOCK.

- Request 2: URI /?id=1%20OR%20'1'='1 xuất phát từ IP 203.210.242.203 (VN) bị chặn bởi rule AWS#AWSManagedRulesSQLiRuleSet#... với Action BLOCK.

- **Đánh giá**:Cả 2 vector tấn công tiêm mã độc (XSS và SQLi) đều bị phát hiện chính xác bởi các Managed Rule Groups tương ứng và bị WAF hủy kết nối ngay tại tầng cân bằng tải, hoàn toàn không chạm tới máy chủ ứng dụng bên trong.

Bằng chứng 3: WAF Rate Limiting / Chống Layer 7 DDoS (Scenario 2)

- **Phân tích hình ảnh thực tế:**
  - **Thực thi trên Terminal:**
    - Chạy vòng lặp kiểm tra trạng thái: for i in {1..10}; do ....
    - Kết quả: Toàn bộ chuỗi từ Request 3: HTTP 403 đến Request 10: HTTP 403 đều nhận mã HTTP 403.
  - **Biểu đồ CloudWatch WAF Metrics:**
    - Biểu đồ số đo lưu lượng của Web ACL ghi nhận đỉnh nhọn (spike) màu tím đại diện cho metric ALL - BlockedRequests vọt thẳng lên mức 10 requests bị chặn tại mốc thời gian Oct 14 11:26.
- **Đánh giá:** Cơ chế giới hạn tần suất phản ứng chính xác. Khi phát hiện lưu lượng truy vấn vượt ngưỡng quy định, bộ luật RateLimit300RequestsPer5Minutes đã lập tức kích hoạt hành động chặn (Block) theo địa chỉ IP nguồn, bảo vệ máy chủ backend khỏi nguy cơ kiệt quệ tài nguyên tính toán.

Bằng chứng 4: Mã hóa Lưu trữ Bằng KMS Customer Managed Key (Scenario 3)

- **Phân tích hình ảnh thực tế:**
    - **Xác thực qua AWS CLI:**
        - Lệnh: aws rds describe-db-instances --db-instance-identifier prod-primary-db --region ap-southeast-1.
        - Kết quả bảng trả về:
            - Tên database: prod-primary-db.
            - Trạng thái mã hóa: True.
            - Khóa KMS: arn:aws:kms:ap-southeast-1:222634368199:key/82da2cdb-0442-4eb8-a706-ba5cd28e5ea0.
    - **Giao diện AWS KMS Console:**
        - Key ID: 82da2cdb-0442-4eb8-a706-ba5cd28e5ea0.
        - Alias: prod-enterprise-cmk.
        - Trạng thái (Status): Enabled.
        - Tab Key material and rotations:
            - Tính năng Automatic key rotation: Trạng thái Enabled (tích xanh).
            - Chu kỳ xoay vòng (Rotation period): 365 ngày.
            - Ngày xoay vòng tiếp theo: Oct 14, 2027.
- **Đánh giá:** Đáp ứng điều khoản CIS 2.8 và 2.9. Cơ sở dữ liệu quan trọng nhất của hệ thống được mã hóa bằng chính khóa CMK riêng của doanh nghiệp với chính sách xoay vòng tự động hàng năm, loại bỏ sự phụ thuộc vào các khóa chia sẻ chung của nhà cung cấp đám mây.

Bằng chứng 5: Tự động Xoay vòng Mật khẩu Secrets Manager (Scenario 4)

- **Phân tích hình ảnh thực tế:**
    - **Xác thực qua AWS CLI:**

        - Lệnh: aws secretsmanager describe-secret --secret-id "$SECRET_ARN" --region ap-southeast-1.
        - Cấu hình JSON trả về:
            - "RotationEnabled": true.
            - "AutomaticallyAfterDays": 30.
            - Nhãn phiên bản: "AWSCURRENT" gắn với version terraform-20261014040021481600000000f.
    - **Giao diện AWS Secrets Manager Console:**
        - Secret name: prod-rds-credentials.
        - Tab Rotation:
            - Trạng thái xoay vòng (Rotation status): Enabled.
            - Lịch xoay vòng (Rotation schedule): 30 days.
            - Ngày xoay vòng gần nhất: Wed, October 14, 2026 at 04:00:23 UTC.
            - Ngày xoay vòng kế tiếp: Fri, November 13, 2026 at 23:59:59 UTC.
            - Hàm Lambda thực thi (Lambda rotation function): prod-db-secret-rotator.
- **Đánh giá**: Chuẩn hóa quản trị dữ liệu định danh theo CIS 1.14. Mật khẩu truy cập cơ sở dữ liệu được quản lý tự động, loại trừ hoàn toàn sự can thiệp thủ công của con người và triệt tiêu nguy cơ lộ mật khẩu qua thời gian

Phase 5:

PHẦN 1: TỔNG KẾT TỔNG QUAN PHASE 5 (EXECUTIVE SUMMARY)

Phase 5 là giai đoạn hoàn thiện cao nhất của dự án, nâng tầm nền tảng từ một hệ thống có tính sẵn sàng cao nội vùng sang kiến trúc Khôi phục sau thảm họa xuyên vùng (Multi-Region Business Continuity and Disaster Recovery - BCDR) theo mô hình Active-Passive (Warm Standby / Pilot Light). Hệ thống đảm bảo duy trì tính liên tục của dịch vụ trước các thảm họa quy mô toàn khu vực làm tê liệt toàn bộ trung tâm dữ liệu tại Primary Region Singapore (ap-southeast-1), cho phép chuyển đổi lưu lượng tự động sang Secondary Region Sydney (ap-southeast-2).

-Kết quả:

- **Vượt xa chỉ tiêu cam kết phục hồi kinh doanh (SLA Resilience Exceeded):**
    - **Recovery Time Objective (RTO):** Đạt 5 phút 22 giây (vượt xa mục tiêu cam kết < 15 phút).
    - **Recovery Point Objective (RPO):** Đạt < 15 giây với ReplicationLag ghi nhận xấp xỉ 0 giây (None), loại bỏ hoàn toàn nguy cơ mất mát dữ liệu giao dịch.
- **Đồng bộ dữ liệu thời gian thực (Physical Cross-Region Replication):** Thiết lập cơ chế streaming replication liên tục từ cụm cơ sở dữ liệu chính prod-primary-db (Singapore) sang bản sao prod-dr-sydney-replica (Sydney), tự động chuyển đổi mô hình lưu trữ và tái mã hóa bằng Customer Managed Key nội vùng Sydney.

- **Điều phối lưu lượng toàn cầu (Global Traffic Management):** Sử dụng Amazon Route 53 Active-Passive Failover kết hợp Route 53 Health Checks với chu kỳ 10 giây/lần từ 8 trạm kiểm thử toàn cầu để tự động phát hiện sự cố vùng biên.
- **Tự động hóa phản ứng thảm họa (Automated SRE Failover):** Vận hành script tự động hóa trigger-dr-failover.sh thực thi việc ngắt luồng sao chép, nâng cấp (Promote) Read Replica thành Primary Database độc lập và tự động mở rộng cụm EC2 Auto Scaling Group tại Sydney từ chế độ Pilot Light (1 instance) lên năng lực phục vụ Production (2 instances).
- **Tính độc lập tuyệt đối của vùng dự phòng:** Vùng Sydney hoạt động trên dải mạng tách biệt hoàn toàn (10.1.0.0/16), khóa mã hóa KMS CMK riêng biệt và S3 state độc lập, đảm bảo không có bất kỳ điểm nghẽn phụ thuộc (Single Point of Failure) nào vào Singapore.

PHẦN 2: GIẢI THÍCH FULL TỪNG BƯỚC ĐÃ THỰC HIỆN

Quy trình thiết lập và diễn tập chuyển vùng sự cố được triển khai theo 6 bước kỹ thuật:

[BƯỚC 1: XUẤT REMOTE STATE SINGAPORE] —> [BƯỚC 2: KHỞI TẠO HẠ TẦNG DR SYDNEY] —> [BƯỚC 3: CROSS-REGION REPLICA]

|

[BƯỚC 6: KIỂM CHỨNG TRUY CẬP SYDNEY] <— [BƯỚC 5: LIVE DR DRILL RUNBOOK] <— [BƯỚC 4: ROUTE 53 HEALTH CHECK]

Bước 1: Mở rộng State Output từ Primary Region Singapore

- **Mục đích:** Cung cấp thông tin kết nối và định danh tài nguyên của Singapore cho môi trường Sydney đọc qua mạng ngầm.
- **Thực thi:** Khai báo xuất các giá trị db_instance_arn và db_password (sensitive) trong outputs.tf của môi trường primary-singapore, sau đó

cập nhật S3 Remote State bucket enterprise-tf-state-222634368199-ap-southeast-1.

Bước 2: Khởi tạo hạ tầng mạng song sinh tại Sydney (dr-sydney)

- **Mục đích:** Chuẩn bị sẵn sàng môi trường tính toán và cân bằng tải mà không gây xung đột định tuyến.
- **Thực thi:** Triển khai module VPC 3-tier tại ap-southeast-2 với dải mạng không trùng lặp 10.1.0.0/16, thiết lập Security Groups, Public Application Load Balancer và tạo riêng một Customer Managed Key (dr_cmk) tại Sydney có chính sách cấp quyền cho Auto Scaling và RDS.

Bước 3: Thiết lập RDS PostgreSQL Cross-Region Read Replica (rds_replica.tf)

- **Mục đích:** Nhân bản dữ liệu vật lý xuyên lục địa.
- **Thực thi:** Khởi tạo instance prod-dr-sydney-replica với tham số replicate_source_db trỏ về ARN của database chính ở Singapore. Quá trình snapshot, truyền tải dữ liệu và tái mã hóa qua KMS CMK Sydney diễn ra tự động trên hạ tầng mạng trục của AWS.

Bước 4: Thiết lập rào kiểm tra sức khỏe Route 53 Health Checks

- **Mục đích:** Giám sát liên tục tính khả dụng của Application Load Balancer Singapore từ bên ngoài Internet.
- **Thực thi:** Cấu hình aws_route53_health_check gửi yêu cầu HTTP probe tới endpoint /healthz của Singapore ALB với tần suất 10 giây/lần và ngưỡng kích hoạt sự cố là 3 lần thất bại liên tiếp (Failure threshold = 3).

Bước 5: Viết và kích hoạt script diễn tập sự cố (trigger-dr-failover.sh)

- **Mục đích:** Chuẩn hóa quy trình phản ứng thảm họa của kỹ sư SRE thành mã lệnh thực thi tự động.
- **Thực thi:** Chạy script ./scripts/trigger-dr-failover.sh. Script kiểm tra tính sẵn sàng của replica, gửi lệnh promote-read-replica, theo dõi quá trình

cơ sở dữ liệu chuyển từ rebooting sang backing-up cho tới khi hoàn tất (available), và lập tức scale Auto Scaling Group Sydney lên 2 máy.

Bước 6: Nghiệm thu chuyển đổi lưu lượng và kiểm tra tính toàn vẹn (Verification)

- **Mục đích:** Xác minh hệ thống tại Sydney đã tiếp nhận toàn bộ tải và cho phép người dùng đọc/ghi dữ liệu.
- **Thực thi:** Truy cập URL Load Balancer của Sydney prod-dr-public-alb-453913900.ap-southeast-2.elb.amazonaws.com, kiểm tra giao diện Diagnostic Hub hiển thị đúng vùng ap-southeast-2a và trạng thái cơ sở dữ liệu báo Connected to [enterprisedb].

PHẦN 3: CẤU TRÚC CHI TIẾT TỪNG FILE MÃ NGUỒN VÀ Ý NGHĨA KỸ THUẬT

1. Module Disaster Recovery (terraform/modules/disaster-recovery/)

- **rds_replica.tf**:
    - *Ý nghĩa:* Quản lý vòng đời của cơ sở dữ liệu bản sao đọc xuyên vùng.
    - *Chi tiết kỹ thuật:*
        - replicate_source_db = var.source_db_instance_arn: Điểm cốt lõi kích hoạt chế độ sao chép vật lý trực tiếp từ Singapore.
        - kms_key_id = var.kms_key_arn: Bắt buộc sử dụng khóa CMK nội vùng của Sydney để mã hóa dữ liệu tĩnh, ngăn chặn lỗi từ chối giải mã xuyên vùng.
        - multi_az = false: Thiết lập Single-AZ trong giai đoạn Warm Standby để tối ưu hóa chi phí vận hành thường nhật.

- **main.tf**:
    - *Ý nghĩa:* Cấu hình kiểm tra sức khỏe và định tuyến phân giải DNS toàn cầu.
    - *Chi tiết kỹ thuật:* Khởi tạo aws_route53_health_check với tham số request_interval = 10 và failure_threshold = 3. Tạo các bản ghi aws_route53_record với chính sách failover_routing_policy phân chia rõ nhánh PRIMARY (Singapore) và SECONDARY (Sydney) dựa trên ID kiểm tra sức khỏe.
- **variables.tf & outputs.tf**:
    - *Ý nghĩa:* Chuẩn hóa giao diện dữ liệu đầu vào và xuất các điểm kết nối.
    - *Chi tiết kỹ thuật:* Xuất replica_endpoint, replica_address (hostname phục vụ app kết nối), replica_id và health_check_id.

2. Môi trường Dự phòng Sydney (terraform/environments/dr-sydney/)

- **backend.tf**:
    - *Ý nghĩa:* Quản lý trạng thái hạ tầng độc lập của vùng Sydney.
    - *Chi tiết kỹ thuật:* Trỏ về S3 bucket enterprise-tf-state-222634368199-ap-southeast-1 với state key riêng biệt dr-sydney/terraform.tfstate, sử dụng use_lockfile = true để khóa đồng thời theo chuẩn Terraform mới.
- **main.tf**:
    - *Ý nghĩa:* File điều phối trung tâm toàn bộ hạ tầng dự phòng Sydney.
    - *Chi tiết kỹ thuật:*
        - Khối data.terraform_remote_state.primary: Đọc dữ liệu từ state của Singapore để lấy ARN database chính và DNS Load Balancer.
        - Khối aws_kms_key.dr_cmk: Khởi tạo khóa CMK tại Sydney, gán chính sách AllowAutoScalingCreateGrant và AllowAutoScalingServiceRole cho

AWSServiceRoleForAutoScaling để tránh lỗi timeout khi máy ảo mở rộng.

        - Module asg: Thiết lập ở cấu hình Pilot Light (min_size = 1, desired_capacity = 1, max_size = 4) nhằm duy trì ít nhất 1 node hoạt động liên tục với chi phí thấp nhất nhưng có thể mở rộng tức thì.
        - Module disaster_recovery: Đấu nối replica vào đúng subnet group và security group của database Sydney.

- **variables.tf**:
    - *Ý nghĩa:* Định nghĩa không gian địa chỉ mạng Sydney.
    - *Chi tiết kỹ thuật:* Khai báo VPC CIDR 10.1.0.0/16, Public Subnets (10.1.1.0/24, 10.1.2.0/24), Private App Subnets (10.1.10.0/24, 10.1.20.0/24), và Isolated DB Subnets (10.1.100.0/24, 10.1.200.0/24).

3. Tầng Kịch bản Diễn tập & Báo cáo Kiểm toán (scripts/ & docs/)

- **scripts/trigger-dr-failover.sh**:
    - *Ý nghĩa:* Tự động hóa hoàn toàn quy trình xử lý sự cố (Automated Incident Mitigation) theo chuẩn SRE.
    - *Chi tiết kỹ thuật:*
        - Sử dụng AWS CLI gọi lệnh aws rds promote-read-replica.
        - Chạy vòng lặp kiểm tra trạng thái database mỗi 15 giây, kiểm soát các trạng thái chuyển giao phức tạp (rebooting, backing-up) cho đến khi database đạt trạng thái sẵn sàng ghi (available).
        - Tự động nhận diện tên ASG của Sydney (prod-dr-asg-...) và gọi lệnh aws autoscaling set-desired-capacity --desired-capacity 2 để mở rộng số lượng node phục vụ.
        - Ghi nhận mốc thời gian bắt đầu và kết thúc để tính toán chính xác chỉ số RTO thực tế.
- **docs/dr-drill-report.md**:

- *Ý nghĩa:* Báo cáo kiểm toán sau diễn tập BCDR chứng minh sự tuân thủ các cam kết SLA của doanh nghiệp.
- *Chi tiết kỹ thuật:* Hệ thống hóa ma trận chỉ số RTO/RPO, nhật ký thực thi theo từng mốc giây (Chronological Log từ T+00:00 đến T+05:22) và các điểm xác thực tính độc lập về mạng, bảo mật và tính toàn vẹn dữ liệu.

PHẦN 4: ĐÁNH GIÁ CHI TIẾT CÁC BẰNG CHỨNG THỰC NGHIỆM (PROOF OF WORK)

Toàn bộ các bằng chứng thực nghiệm trong Phase 5 đều được thu thập trực tiếp từ AWS CLI, bảng điều khiển AWS Management Console và giao diện người dùng thực tế:

Bằng chứng 1: Kiến trúc Tầng Disaster Recovery & Business Continuity

- Sơ đồ phân định rõ 2 vùng địa lý: ap-southeast-1 (Primary) và ap-southeast-2 (DR).
- Luồng sao chép: Dữ liệu từ cụm RDS Primary được truyền bất đồng bộ xuyên vùng tới RDS Cross-Region Read Replica.
- Tầng phân phối: Route 53 Failover Routing đóng vai trò van điều tiết lưu lượng giữa Primary ALB và hạ tầng dự phòng.

- **Đánh giá:** Mô hình phân bổ chuẩn xác cấu trúc Active-Passive Warm Standby/Pilot Light.

Bằng chứng 2: Trạng thái Đồng bộ RDS Cross-Region Replica (Scenario 1)

- **Xác thực qua AWS CLI (ap-southeast-2):**
  - Tên DB: prod-dr-sydney-replica.
  - Trạng thái hoạt động: available.

        - Endpoint kết nối: prod-dr-sydney-replica.chqkyga2un9r.ap-southeast-2.rds.amazonaws.com.
        - Độ trễ sao chép (ReplicationLag): None (tương đương 0 giây).
    - **Bảng điều khiển AWS RDS Console (Mục Replication):**
        - Bản ghi 1: prod-dr-sydney-replica mang Role Replica, nằm tại ap-southeast-2a, có Replication source trỏ trực tiếp về prod-primary-db, trạng thái sao chép báo xanh Replicating.
        - Bản ghi 2: prod-primary-db (Singapore) mang Role Primary tại ap-southeast-1.
- **Đánh giá:** Hoàn hảo về tính toàn vẹn dữ liệu (RPO < 15s). Cơ chế streaming physical replication vận hành liên tục và ổn định xuyên lục địa mà không ghi nhận bất kỳ độ trễ tồn đọng nào.

Bằng chứng 3: Route 53 Health Checks & Failover Routing (Scenario 2)

- **Phân tích hình ảnh thực tế (proof-route53-healthcheck.png):**
    - **Chi tiết cấu hình Health Check:**
        - ID giám sát: eefd9727-11e6-473d-a534-c72bdcdef663.
        - URL thăm dò: http://prod-public-alb-1077463751.ap-southeast-1.elb.amazonaws.com:80/healthz.
        - Chu kỳ: Request interval = 10 seconds, Ngưỡng lỗi: Failure threshold = 3.
        - Trạng thái tổng quan: Status: Healthy (màu xanh lá).
    - **Phạm vi giám sát toàn cầu** (8 Checker Regions): Hoạt động đồng thời từ US East, US West, Tokyo, Singapore, Sydney, Ireland, Sao Paulo.
    - **Biểu đồ Metrics:** Cả 2 đồ thị *Health check status* và *Health checkers that report the endpoint healthy (percent)* duy trì tuyệt đối ở mức **100%** ổn định xuyên suốt thời gian theo dõi.

- **Đánh giá:** Hệ thống giám sát biên đạt độ nhạy cao, sẵn sàng phát hiện sự cố mất tính sẵn sàng của Singapore trong vòng tối đa 30 giây để kích hoạt chuyển hướng DNS.

Bằng chứng 4: Tự động hóa Diễn tập Chuyển vùng Sự cố (Scenario 3)

- **Nhật ký thực thi kịch bản CLI (./scripts/trigger-dr-failover.sh):**
    - Giai đoạn khởi động: Phát hiện replica sẵn sàng, phát lệnh promote và theo dõi trạng thái.
    - Quá trình chuyển đổi trạng thái database: Chuyển qua trạng thái rebooting, sau đó chuyển sang backing-up (polled đều đặn mỗi 15 giây qua 10 chu kỳ).
    - Xác nhận độc lập: --> [SUCCESS] Database is now standalone and accepting write transactions!.
    - Mở rộng tính toán: Tự động phát hiện ASG prod-dr-asg-20261014162209685500000001 và scale desired capacity lên 2 instances.
    - Thông báo hoàn tất: DISASTER RECOVERY FAILOVER COMPLETED SUCCESSFULLY!.
    - Kết quả đo lường RTO thực tế: Operational Recovery Time (RTO): 5m 22s.
- **Đánh giá:** Thực thi SRE mẫu mực. Toàn bộ chuỗi thao tác phức tạp từ tách cụm DB, sao lưu dữ liệu, cấu hình lại quyền ghi/đọc đến nâng cấp quy mô máy ảo được giải quyết tự động trong vòng 5 phút 22 giây.

Bằng chứng 5: Nâng cấp Replica thành Standalone Primary (Scenario 4)

- **AWS RDS Console (ap-southeast-2):**
    - DB identifier: prod-dr-sydney-replica.
    - Trạng thái: Available.

        - Phân định vai trò (Role): Đã chính thức chuyển đổi từ Replica thành Instance (Standalone Primary Database).
        - Bảng Replication: Cột Replication source chuyển thành - (None), chứng minh cơ sở dữ liệu đã cắt đứt hoàn toàn liên kết phụ thuộc vào Singapore.
        - Động cơ vận hành: PostgreSQL trên instance class db.t4g.micro tại vùng sẵn sàng ap-southeast-2a.
- **Đánh giá:** Cơ sở dữ liệu tại Sydney đã giải phóng các ràng buộc chỉ đọc (Read-Only) để trở thành một hệ thống quản trị cơ sở dữ liệu độc lập, tiếp nhận toàn quyền đọc và ghi dữ liệu phục vụ ứng dụng.

Bằng chứng 6: Chuyển dịch Lưu lượng và Phục hồi Hệ thống tại Sydney (Scenario 5)

- Trình duyệt truy cập Load Balancer Sydney:
    - URL: http://prod-dr-public-alb-453913900.ap-southeast-2.elb.amazonaws.com.
- Thông số chẩn đoán trên giao diện Web (Enterprise 3-Tier Diagnostic Hub):
    - INSTANCE ID: i-0022dc2913fc2b85d.
    - AVAILABILITY ZONE: ap-southeast-2a (màu xanh lá).
    - PRIVATE IPV4 ADDRESS: 10.1.10.169 (nằm trong dải mạng nội bộ Sydney 10.1.10.0/24).
    - DEPLOYMENT ENVIRONMENT: production.
    - DATABASE CONNECTION STATUS (RDS MULTI-AZ): Connected to [enterprisedb] at Wed Oct 14 2026 18:18:40 GMT+0000.
- **Đánh giá:** Toàn bộ 3 tầng (ALB, Compute EC2, Database PostgreSQL) tại Sydney đã hợp nhất và vận hành thông suốt. Ứng dụng kết nối trực tiếp vào database nội vùng đã promote mà không gặp bất kỳ lỗi kết nối hay rớt phiên nào.

TỔNG KẾT DỰ ÁN TOÀN DIỆN (5 PHASES)

Bảng đối chiếu hoàn thành 5 Giai đoạn:

- **Phase 1 (Hạ tầng nền tảng):** Xây dựng kiến trúc 3-Tier VPC có tính sẵn sàng cao, Auto Scaling Group dùng chip ARM Graviton và RDS Multi-AZ kết hợp quản trị Zero-Trust qua AWS SSM.
- **Phase 2 (Tự động hóa GitOps & CI/CD):** Xác thực phi mật khẩu qua IAM OIDC, rào chắn an ninh ca trái Checkov/Trivy, và phát hành liên tục Zero-Downtime với AWS CodeDeploy.
- **Phase 3 (Quan sát chuyên sâu & SRE):** Thu thập số đo RAM/Disk từ CloudWatch Unified Agent, Dashboard-as-Code hợp nhất, kiểm thử Synthetics Canary và quy trình ứng cứu sự cố chuẩn hóa (SRE Runbook).
- **Phase 4 (Gia cố an ninh & Tuân thủ):** Tường lửa AWS WAF v2 chống OWASP Top 10/DDoS, mã hóa dữ liệu tĩnh bằng KMS Customer Managed Key, tự động xoay vòng mật khẩu Secrets Manager và đạt chuẩn CIS AWS Foundations Benchmark (>90%).
- **Phase 5 (Khôi phục sau thảm họa BCDR):** Thiết lập mô hình Multi-Region Warm Standby/Pilot Light giữa Singapore và Sydney, tự động hóa chuyển vùng với Route 53 và RDS Read Replica, đạt chỉ số RTO 5 phút 22 giây và RPO < 15 giây